SOAR Project - What Must Be Built

1. Machine Learning Model

- Trained Random Forest, scaler and feature list (DONE)
- Prediction API returning label, probabilities and top features
- Live sniffer feature names and order must match the training columns
- Per-class evaluation report (precision, recall, F1, confusion matrix)
- Drift monitor: daily class mix and key-feature statistics

2. Data Pipeline

- Redis Streams replace flows.csv (events, alerts, incidents, actions, audit)
- One unified event schema shared by all components
- Consumer groups, acknowledgements and a dead-letter stream
- Sniffer (cicflowmeter) writes flows directly to Redis
- Log shipper for skyline-web and HAProxy logs; website emits login events
- HAProxy forwardfor so the real client IP is logged
- Fix the detector bug: KeyError flows_in_window

3. Detection

- Rate-based layer rebuilt on the stream
- YAML rule engine with 15+ rules (brute force, scanning, SQL injection patterns, uploads, abnormal status codes)
- HAProxy stick tables to reject floods instantly (HTTP 429)

4. Correlation and Severity

- Alerts grouped into incidents (same IP + attack family, sliding window)
- Sequence and cross-source correlation
- Severity score formula with stored breakdown (Critical, High, Medium, Low)

5. Threat Intelligence and Enrichment

- VirusTotal client for IP, domain, URL and file hash
- Quota governor (about 4 per minute, 500 per day), cache with TTL, never send private IPs
- AbuseIPDB and GeoIP (country, ASN, coordinates)
- Enrichment service: parallel lookups, partial results, one evidence bundle per incident
- Indicator store with expiry and STIX export

6. MITRE ATT&CK

- Load ATT&CK v19 STIX data and read tactics from the data
- Map every alert and incident to technique IDs
- Coverage analysis and Navigator layer export

7. AI Agent (replaces SOC Tier 1)

- LLM gateway: timeouts, retries, fallback model, cost tracking
- Tool registry and bounded reasoning loop
- Context builder with personal-data masking and untrusted-data delimiters
- Versioned prompt library with few-shot examples (including false positive and uncertain cases)
- Strict JSON decision schema with validator
- Confidence gates G0 to G3 that limit what it may execute by itself
- Memory per IP and analyst corrections
- Fallback decision engine when the LLM fails
- Reporter agent (incident summaries) and Tuning agent (rule proposals)
- Evaluation: golden set of 50+ incidents, agent versus fallback

8. Safety and Control

- Policy Guard in code: allowlist, maximum block time, maximum blocks per minute, scope check
- Kill switch and autonomy modes (Autonomous, Shadow, Paused)
- Prompt-injection defences and a red-team test suite
- Tamper-evident audit log of every decision and action

9. Playbooks and Executor

- Playbook engine: YAML, conditions, parallel steps, retries, timeouts, dry-run
- Executor with idempotency keys, retries and audit records
- Ten playbooks written and tested

10. Automatic Response

- HAProxy blocking through the runtime API (add acl / del acl) with TTL, file sync and verification
- Escalating block durations for repeat offenders
- Rate-limit and tarpit actions
- Website hooks: lock account, revoke sessions, block a request pattern
- Undo for every action

11. Case Management

- Cases created automatically with states and SLA timers
- Notes, timeline, evidence and closure form (root cause, lessons learned)

12. Penetration Testing

- Website mode A (deliberately vulnerable) and mode B (hardened)
- Scope lock and containerised scan runner
- Wrappers for Nmap, OWASP ZAP, Nikto, sqlmap, Hydra
- Parsers into unified findings (CWE, OWASP category, CVSS)
- Planner agent, PDF report and retest with before/after comparison
- Pentest traffic labelled as authorised; record which attacks the SOAR detected
- Attacker container with scripted scenarios, including a false-positive case

13. GRC: Assets and Risk

- Asset inventory with criticality 1 to 5
- Risk register with live likelihood x impact scoring and 5x5 heatmap
- Key Risk Indicators

14. GRC: Compliance

- Control library: NIST CSF 2.0, ISO 27001 Annex A, CIS v8, OWASP Top 10 (verify against official texts)
- Compliance scoring per framework
- Automatic evidence collection with hash and timestamp
- Policy library, with policies linked to the playbooks they control
- Remediation tracker that closes only after a successful retest

15. Notifications and Reports

- Telegram, email and webhook with routing, deduplication and escalation
- Executive and technical PDF reports, on demand and weekly

16. Dashboard

- Framework: login, roles, themes, live updates, stats API with indexes
- Operations: Command Center, Live Threat Map, Alerts Explorer, Incident Workbench, Case Board
- Agent and response: AI Agent Console, Actions Ledger, Blocklist, Playbook Studio
- Intelligence: Threat Intelligence Hub, ATT&CK Coverage
- Pentest: Pentest Center, Findings
- GRC: Assets, Risk Register, Compliance, Policies, Evidence and Audit, Reports
- Platform: Sources Health, Platform Health, Admin and RBAC, Client Portal

17. Platform Security and Reliability

- JWT login, role-based access, secrets outside git, non-root containers
- Health checks, metrics, correlation id, defined fallback for every dependency
- Backups with a tested restore

18. Testing and Validation

- Synthetic load generator (documented as a stress test, separate from detection accuracy)
- Chaos tests: stop Redis, stop the LLM, exhaust the VirusTotal quota
- Acceptance criteria measured: detection to block under 15 seconds, zero wrong destructive actions, allowlisted IP never blocked

19. Delivery

- One Docker Compose for the whole platform and a CI test job
- Architecture diagram, READMEs, final report with limitations and future work
- Demo script rehearsed end to end

20. Optional Extras (only after everything above works)

- Honeypot paths, attack replay, ModSecurity, Suricata, multi-tenant mode